GUIDE D'INTERVENTION EN CAS DE CRISE D'ACCÈS

Procédures standardisées de rétablissement du compte Coordonnateur et de restauration des services

POINT D'ENTRÉE D'URGENCE	INSTANCE SUPABASE PRODUCTION	DOMAINE & SMTP OFFICIELS
Ordinateur avec session Supabase Cloud ouverte	Projet : gedmhgcdhghionubfoih	LWS · groupe-secretdelareussite.com

SCÉNARIO 2 : PERTE TOTALE D'ACCÈS (Email inaccessible & Mot de passe perdu)

Contexte : L'application web est verrouillée de l'intérieur. L'équipe légitime ne peut plus recevoir d'email de réinitialisation. L'intervention s'effectue hors-bande via le

OPTION A : Réinitialiser directement le compte coordonnateur existant

Recommandée (Zéro impact sur les données)

1. Se connecter au Dashboard Supabase de production (**gedmhgcdhghionubfoih**) puis ouvrir le menu **Authentication > Users**.
2. Localiser le compte du coordonnateur dans la liste (recherche par username ou ancien email).
3. Cliquer sur les trois points **[...]** à droite de la ligne et choisir **"Set User Password"**.
4. Saisir un mot de passe robuste (e 12 caractères). Si l'email doit être remplacé par un nouvel email actif du groupe, modifier l'email dans le dialogue puis synchroniser la table applicative via le SQL Editor :

```
-- Synchroniser le nouvel email dans la table applicative GSR
UPDATE public.users
SET email = 'direction@groupe-secretdelareussite.com'
WHERE username = 'admin';
```

5. **Résultat :** Le coordonnateur peut immédiatement se reconnecter sur **/admin/login** avec son nom d'utilisateur et le nouveau mot de passe.

OPTION B : Créer un nouveau compte coordonnateur d'urgence

Alternative propre en cas d'ancien compte corrompu

1. Dans **Authentication > Users**, cliquer sur le bouton vert **"Add user" > "Create user"**.
2. Saisir le nouvel email officiel du groupe, définir son mot de passe initial, et cocher impérativement **"Auto Confirm User"**.
3. Copier l'**Identifiant UUID** du compte généré (ex: **"e4b2a1c0-7f99-4a21-99bc-..."**).
4. Ouvrir l'onglet **SQL Editor** sur Supabase et exécuter la requête d'enregistrement :

```
-- Associer le compte Auth aux privilèges du rôle Coordonnateur
INSERT INTO public.users (id, username, email, role, actif)
VALUES (
  'UUID_COPIE_CI_DESSUS',
  'coord_secours',
  'nouvel_email@groupe-secretdelareussite.com',
  'coordonnateur',
  true
);
```

5. **Résultat :** Le compte de secours est actif avec 100% des droits coordonnateur.

SCÉNARIO 3 : PIRATAGE OU COMPROMISSION MALVEILLANTE DU COMPTE COORDONNATEUR

Les 3 méthodes constituent une séquence chronologique indissociable : Stopper l'attaquant ' Reprendre le contrôle ' Restaurer l'intégrité des données scolaires.

PHASE 1 : ENDIGUEMENT IMMÉDIAT (Éjection de l'attaquant)

Priorité Absolue · T0 + 5 min

A. **Changer le mot de passe et l'email immédiatement :** Dans Supabase **Authentication > Users**, cliquer sur le compte compromis et forcer un nouveau mot de passe inconnu du pirate.

B. **Révocation globale de toutes les sessions actives :** L'attaquant peut avoir des onglets ouverts avec des cookies JWT encore valides. Pour le déconnecter instantanément, exécuter dans le **SQL Editor** :

```
-- Invalider immédiatement tous les tokens et sessions du compte compromis
DELETE FROM auth.sessions WHERE user_id = 'UUID_DU_COORDONNATEUR';
DELETE FROM auth.refresh_tokens WHERE session_id IN (
  SELECT id FROM auth.sessions WHERE user_id = 'UUID_DU_COORDONNATEUR'
);
```

PHASE 2 : REPRISE EN MAIN & AUDIT DES ACCÈS STAFF

Nettoyage des Privilèges

A. **Vérifier l'absence de comptes pirates créés :** Le pirate a pu créer un faux compte administrateur secondaire pour garder une porte dérobée (*backdoor*).

```
-- Lister tous les comptes ayant accès à la plateforme
SELECT id, username, email, role, actif FROM public.users ORDER BY role;
```

B. **Désactiver tout compte suspect :** Exécuter **UPDATE public.users SET actif = false WHERE id = '...';**

PHASE 3 : RESTAURATION DES DONNÉES (Sauvegarde saine GitHub Actions)

Rétablissement RPO 3h du matin

A. **Localiser la sauvegarde saine :** Ouvrir l'organisation GitHub du client **groupesecretdelareussite/projet_gsr**.

B. Basculer sur la branche **backups**. Télécharger le dernier dump SQL chiffré/compressé **backups/gsr-YYYY-MM-DD.sql.gz** précédant l'intrusion (généré chaque jour à 3h).

C. **Restaurer dans Supabase :** Décompresser l'archive. Les tables **public** (élèves, paiements, présences, notes) et **td** sont automatiquement remises à zéro et réinjectées sans corrompre le système.

D. **Sécurité Auth garantie :** Comme le dump exclut volontairement **auth.users**, le hacker ne peut en aucun cas réutiliser ses anciens mots de passe ! Le coordonnateur recrée simplement les accès sains pour son staff.

CHECKLIST DE CLÔTURE DE CRISE

[OK] Sessions pirates invalidées et mot de passe maître modifié.
[OK] Intégrité des tables financières (paiements et remises) vérifiée.
[OK] Second compte coordonnateur de secours configuré avec mot de passe sous scellé.
[OK] Information des chefs de site et reprise normale des encaissements et appels.